

SIMATS ENGINEERING

ASSESSMENT TOOL 3 – CASE STUDY

COURSE CODE: ITA14

COURSE NAME: Ethical Hacking

COURSE OUTCOME COVERED

CO4: Implement network security testing methods by performing web server attacks, analyzing web application vulnerabilities, and assessing wireless network security using Kali Linux. (BT4, BT5)

Assessment Tool Weightage: 35%

QUESTIONS: 5

Total Marks:100

Code of Conduct:

I G. Nithya Sree (192424103) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: G. Nithya Sree

Question 1 – Apache Web Server Security Assessment

Case Analysis

The unauthorized transactions and abnormal account activity indicate that the e-commerce application may have been compromised through several connected weaknesses. The suspicious HTTP requests for hidden directories suggest that the attacker first performed reconnaissance and directory enumeration to discover administrative pages, backup files, configuration files, or sensitive application resources.

The malicious scripts submitted through input fields indicate a possible Cross-Site Scripting (XSS) vulnerability. If the application displays untrusted input without proper output encoding, malicious content could execute in a customer's browser. This may result in session theft, phishing, or unauthorized actions. Poor handling of database-related input could also expose the application to SQL Injection.

Another major issue is the outdated Apache server. Older versions may contain known vulnerabilities and unsupported components. The absence of a Web Application Firewall (WAF) further increases the risk because suspicious requests can directly reach the application.

Assessment Approach

An authorized assessment should begin with reconnaissance to identify open ports, running services, HTTP headers, server technologies, and exposed resources. Vulnerability scanning can then identify server misconfigurations, missing security headers, outdated components, and exposed directories. Findings should be manually validated to avoid false positives.

Server logs should also be analyzed to identify repeated directory requests, unusual input patterns, failed authentication attempts, and suspicious transaction activity. Correlating these events can help determine the possible attack path.

Impact

A successful compromise could affect:

- Confidentiality: Customer accounts and personal information may be exposed.
- Integrity: Attackers may manipulate transactions or account data.
- Availability: Exploitation or malicious requests may disrupt web services.

Layered Defense Strategy

The organization should:

1. Regularly patch Apache, Linux, and all installed components.
2. Disable unnecessary Apache modules and directory listing.
3. Store configuration and backup files outside the public web directory.
4. Implement server-side input validation and parameterized database queries.
5. Apply context-specific output encoding and a Content Security Policy.
6. Use HTTPS and secure session cookies.
7. Deploy a WAF to filter suspicious HTTP requests.
8. Use IDS/IPS, firewalls, centralized logging, and network segmentation.
9. Monitor transactions and authentication activity for anomalies.

Conclusion

The incident is best understood as a chain of weaknesses rather than a single vulnerability. Combining patch management, secure coding, WAF protection, strong authentication, and continuous monitoring provides a practical defense-in-depth solution.

Question 2 – SQL Injection and XSS in a Financial Application

Case Analysis

This financial application processes sensitive customer information and transactions. The discovery of SQL Injection, XSS, detailed database error messages, and poor input sanitization indicates serious weaknesses in the application's secure coding practices.

SQL Injection occurs when untrusted input influences a database query. This may allow an attacker to bypass intended application logic or access sensitive records. The detailed database errors worsen the problem because they can reveal information about database structure and help attackers understand how the application works.

XSS occurs when malicious user input is returned to a browser without proper output encoding. If the malicious content is reflected or stored, it may execute when another user views the affected page. In this case, that could lead to phishing, session misuse, or unauthorized actions.

Security Audit Methodology

During an authorized assessment, **Burp Suite** can be used to inspect HTTP requests from login, account, and transaction functions. The tester can analyze input parameters, cookies, authentication tokens, and server responses.

Suspected SQL Injection issues can be validated using an authorized automated scanner such as SQLmap, followed by manual verification. XSS testing should determine whether user-controlled data is reflected or stored and whether output encoding is correctly applied.

CIA Triad Analysis

Confidentiality: Attackers may obtain customer details, account information, and financial records.

Integrity: Account information or transactions may be altered if application controls are bypassed.

Availability: Attacks against the application or database could disrupt services for legitimate users.

Solution Design

The organization should implement:

- [illegible]

Question 3 – Evil Twin Attack on Corporate Wi-Fi

Case Analysis

The unusual login prompts and slow network performance strongly suggest that employees were connecting to a rogue access point. The attacker created an Evil Twin by imitating the legitimate organization's Wi-Fi identity.

Employees may connect because the fake network appears familiar. Once users connect, the attacker can attempt credential phishing or intercept insecure communication. This can create a man-in-the-middle (MITM) situation.

The use of WPA2-PSK is a weakness because users may share the same password. If the password is weak or exposed, unauthorized access becomes easier. A shared password also provides poor accountability because individual users cannot be easily distinguished by the wireless authentication process.

Detection and Investigation

An authorized investigation should identify and compare:

- SSIDs
- BSSIDs
- Channels
- Signal strength
- Security configuration

An unexpected access point using the organization's SSID or an unfamiliar BSSID may indicate an Evil Twin. Packet analysis can also identify suspicious DNS responses, unusual authentication activity, insecure HTTP communication, and unexpected traffic patterns.

Impact

The attack may result in:

- Credential theft.
- Account compromise.
- Interception of sensitive information.
- Unauthorized access to internal services.
- Loss of employee trust.

Solution Design

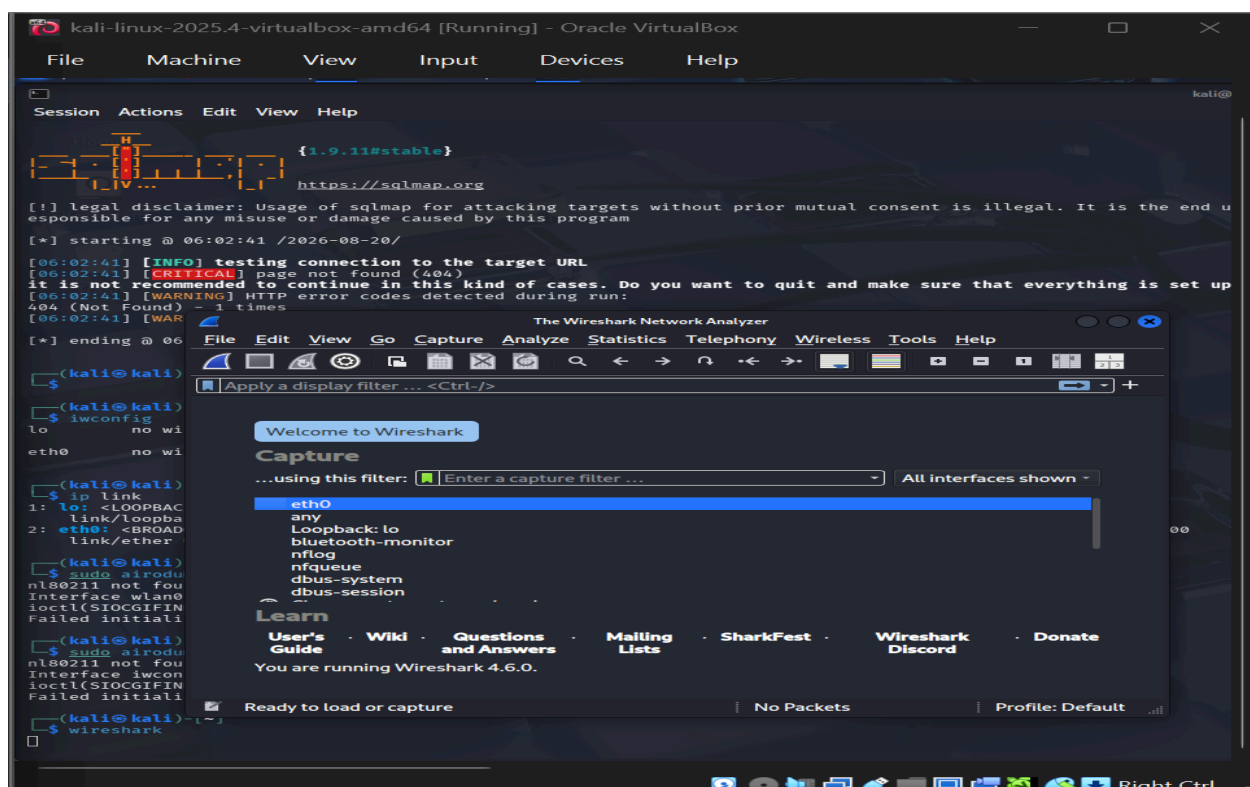
The organization should replace the shared WPA2-PSK approach with WPA3-Enterprise or WPA2-Enterprise using 802.1X authentication. Individual credentials or certificates improve identity verification and accountability.

Additional controls should include:

- Wireless IDS/IPS for rogue AP detection.
- Continuous monitoring for duplicate SSIDs and unknown BSSIDs.
- HTTPS and strict certificate validation.
- Network segmentation.
- User awareness training.
- A policy requiring employees to report unexpected login prompts.

Conclusion

The Evil Twin attack succeeds by combining a technical weakness with user trust. Enterprise authentication, continuous wireless monitoring, secure encryption, and employee awareness provide a strong layered defense.



Question 4 – Wireless Network to Web Application Attack Chain

In this scenario, the attacker first gains access to the organization's Wi-Fi network because of **weak wireless passwords**. Once connected to the internal network, the attacker can identify available systems and access the employee management web application. Weak authentication and poor session management may then allow unauthorized access to confidential employee data.

1. Reconnaissance

The attacker first identifies active hosts and services on the authorized internal network. In a penetration-testing environment, tools such as **Nmap** can be used to identify open ports and running services.

This helps identify web servers, databases, and other accessible systems.

2. Scanning and Web Application Testing

After identifying the web application, tools such as **Nmap, Nikto, Burp Suite, or OWASP ZAP** can be used to examine:

- Open services and server versions
- Web-server misconfigurations
- Weak authentication
- Session management issues
- Input validation vulnerabilities

Burp Suite can intercept HTTP requests and help test whether authentication and authorization controls are properly enforced.

3. Exploitation and Privilege Escalation

If the application has weak authentication or poor access control, an attacker may attempt to access resources belonging to another user or reach restricted administrative functions.

Privilege escalation may occur because of:

- Missing authorization checks
- Weak role-based access control
- Insecure session handling
- Predictable or improperly protected session identifiers

This could allow access to confidential employee information.

4. Defense-in-Depth Strategy

The organization should implement security controls at multiple layers:

Wireless Security

- Use WPA3 or WPA2-Enterprise.
- Enforce strong passwords and individual authentication.
- Separate employee and guest networks.

Network Security

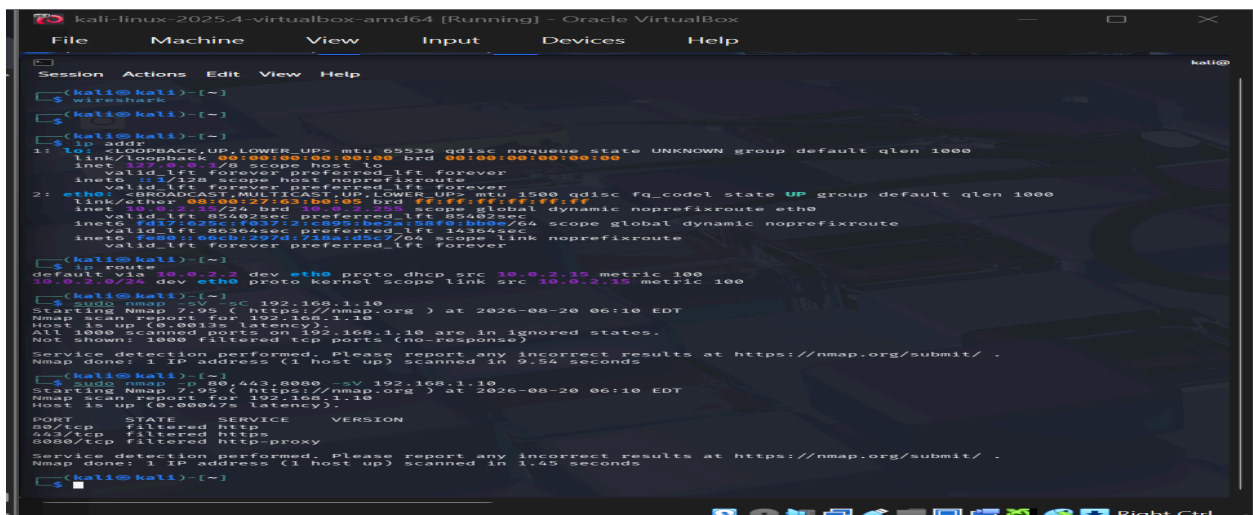
- Use firewalls and network segmentation.
- Prevent Wi-Fi users from directly accessing critical servers.
- Deploy IDS/IPS for suspicious activity.

Web Application Security

- Implement strong authentication and MFA.
- Use secure session management.
- Enforce role-based access control.
- Validate user input and perform regular security testing.

Conclusion

The attack demonstrates how a weak wireless network can provide an entry point to internal systems. A strong **defense-in-depth approach** combining wireless security, network segmentation, secure authentication, web application security, and continuous monitoring can prevent an attacker from moving from Wi-Fi access to confidential employee data.



```
kali@kali:~$ ifconfig
eth0: flags=4096<UP,BROADCAST,MULTICAST> mtu 1500
    link/ether 92:00:0a:00:00:00 brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0
        valid_lft 85402sec preferred_lft 85402sec
    inet6 fd17:e28c:f637:25c895:be2a:18f0:bb0e/64 scope global dynamic noprefixroute
        valid_lft 85364sec preferred_lft 14364sec
    inet6 fe80::6ecb:297d:719a:d5c7/64 scope link noprefixroute
        valid_lft forever preferred_lft forever

kali@kali:~$ ip addr
1: lo: loopback,UP,LOWER_UP< mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host noprefixroute
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: eth0: /BROADCAST,MULTICAST,UP,LOWER_UP< mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 92:00:0a:00:00:00 brd ff:ff:ff:ff:ff:ff
    inet 10.0.2.15/24 brd 10.0.2.255 scope global dynamic noprefixroute eth0
        valid_lft 85402sec preferred_lft 85402sec
    inet6 fd17:e28c:f637:25c895:be2a:18f0:bb0e/64 scope global dynamic noprefixroute
        valid_lft 85364sec preferred_lft 14364sec
    inet6 fe80::6ecb:297d:719a:d5c7/64 scope link noprefixroute
        valid_lft forever preferred_lft forever

kali@kali:~$ ip route
default via 10.0.2.2 dev eth0 proto dhcp src 10.0.2.15 metric 100
10.0.2.0/24 dev eth0 proto kernel scope link src 10.0.2.15 metric 100

kali@kali:~$ nmap -sV -sC 192.168.1.10
Starting Nmap 7.95 ( https://nmap.org ) at 2025-08-20 06:10 EDT
Nmap scan report for 192.168.1.10
Host is up (0.0011s latency).
All 1000 scanned ports on 192.168.1.10 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 9.54 seconds

kali@kali:~$ nmap -p 80,443,8080 -sV 192.168.1.10
Starting Nmap 7.95 ( https://nmap.org ) at 2025-08-20 06:10 EDT
Nmap scan report for 192.168.1.10
Host is up (0.0007s latency)

```

Question 5 – Wi-Fi Deauthentication Attack

A **deauthentication attack** is a wireless denial-of-service attack in which an attacker sends forged deauthentication frames to disconnect users from a Wi-Fi access point. By repeatedly sending these frames, legitimate users are continuously disconnected and cannot access the network properly.

Detection and Analysis

In an authorized and controlled environment, Kali Linux wireless tools can be used to monitor wireless traffic and identify unusual deauthentication activity. **Wireshark** can analyze captured packets and detect a high number of deauthentication or management frames.

Security analysts can examine:

- Repeated disconnection events
- Number of affected devices
- Frequency of deauthentication frames
- Suspicious wireless devices

Impact on the Network

The main impact is on the **Availability** part of the CIA triad. Frequent disconnections can affect:

- Online classes and meetings
- Internet access
- Cloud applications
- Employee or student productivity

Although the attacker may not directly steal data, the repeated disruption can cause a serious denial-of-service situation.

Mitigation Strategies

The university should implement:

- **802.11w Protected Management Frames (PMF)** to protect management frames.
- **WPA3** or other modern wireless security protocols.
- Wireless IDS/IPS to detect abnormal deauthentication activity.
- Regular firmware updates for access points.
- Multiple access points and network redundancy.
- Continuous monitoring of wireless traffic and logs.

The deauthentication attack exploits weaknesses in wireless management frame handling to repeatedly disconnect legitimate users. The best protection is a combination of Protected Management Frames, WPA3, wireless intrusion detection, updated access points, and continuous network monitoring.

[illegible]